

Eyvan Jekyll Template Audit Report

1. Executive Summary

- **What Eyvan does:** Eyvan is a visually minimalist, feature-rich Jekyll template for personal portfolios, academic profiles, research notes, and long-form technical writing. It ships a complete publishing system — layouts, heavily-documented Liquid includes, an ITCSS/BEM Sass architecture, vanilla-JS interactions (theme toggle, mobile menu, mobile TOC, share, back-to-top), tag archives via `jekyll/tagging`, opt-in MathJax, a numbered figure/video/audio/table media system with cross-references, and a GitHub Actions deployment path.
- **Overall score: 78% (94 / 120)**
- **Overall risk rating: Low–Moderate.** Structurally sound and safe to build/deploy; the open issues are real but small and localized.
- **Recommendation: Adopt with minor improvements.**
- **Top 3 strengths:**
 - i. Exemplary template hygiene — every include/layout is documented, parameterized, and uses `relative_url` / `absolute_url` correctly. Builds produce **zero** hardcoded root-relative links, so the `/eyvan` subpath and root deployments both work.
 - ii. Clean, disciplined ITCSS + BEM Sass (correct layer separation, `!important` confined to the trumps layer, no ID selectors) and small, un-obfuscated vanilla JS (~845 lines total).
 - iii. Genuine QA tooling shipped in-repo (pa11y-ci + Playwright/axe), accessible markup foundations (skip link, landmarks, `aria-*`, reduced-motion, focus states), and strong beginner-facing documentation.
- **Top 3 risks:**
 - i. **Google Analytics loads on every page with an empty `?id=`** even though `google_analytics: ""` — the Liquid guard fails because an empty string is truthy. This contradicts the documented "leave blank to disable" and creates an unexpected third-party request by default.
 - ii. **The template fails its own accessibility tests.** Playwright + axe report four distinct violations shipping in the template (duplicate "Social links" landmarks, invalid `role="listitem"` on share `<a>` / `<button>`, content outside landmarks, and an `h1` → `h4` heading-order skip).
 - iii. **Deploy-as-is SEO footgun:** the shipped `url: "http://localhost:4000"` is emitted verbatim into every canonical tag, `og:url`, and the sitemap; `head.html` also advertises an RSS `/feed.xml` that is never generated (no `jekyll-feed`).

2. Repository Context

Field	Value
Repository name	eyvan
Template/project type	Reusable Jekyll template (posts-as-projects portfolio); ships demo content
Main technologies	Jekyll 4.4.1, Kramdown (GFM), Rouge, SCSS (sass-embedded), vanilla JS, MathJax (opt-in)
Jekyll / Ruby / Bundler	Jekyll ~> 4.4 (4.4.1 resolved); local Ruby 4.0.1, Bundler 4.0.8; CI pins Ruby 3.2
Dependency managers	Bundler (Gemfile) for the site; npm (package.json) for QA-only dev tooling
CI/CD	GitHub Actions (.github/workflows/jekyll-pages.yml) → GitHub Pages
Hosting/deployment target	GitHub Pages via Actions (required, because jekyll/tagging is unsupported by the native builder)
Documentation	Strong README + extensively commented includes + a demo "Front Matter Field Reference" post
License	MIT (LICENSE , © 2025 Amir Hosein Sadeghi Isfahani); package.json MIT
Demo site	https://amirhs1.github.io/eyvan/ (not fetched; external verification out of scope)
Date of audit	2026-06-02

3. Scorecard

Category	Score	Weight	Notes
Build and deployment reliability	16	20	Clean builds at / and /eyvan ; zero hardcoded links; valid workflow. Lost points: url: localhost baked into canonical/sitemap, broken /feed.xml link, tooling files leak into _site .
Jekyll architecture and content model	18	20	Outstanding, documented, reusable includes/layouts; coherent media system; posts-as-projects clearly documented. Minor: orcid/medium icon gap, share-button markup.

Category	Score	Weight	Notes
Configuration and front matter design	7	10	Sensible defaults, permalink, graceful optional fields. Lost points: GA empty-string guard defect; localhost url default.
Liquid code quality and structure	8	10	Highly readable, parameterized, good missing-field handling. Lost points: empty-string truthiness bug; role="listitem" on interactive elements.
SCSS architecture and maintainability	9	10	Correct ITCSS layering, BEM prefixes, tokens, !important only in trumps, no IDs.
Accessibility	10	15	Good foundations and real tooling, but ships 4 axe violations detected by its own tests.
Performance and SEO	6	10	Self-hosted fonts (swap), compressed CSS, lazy media, opt-in math. Lost points: no width / height on images (CLS), GA-by-default request, polyfill.io , localhost canonical, broken feed, heavy demo images.
Security, dependencies, and supply chain	7	10	npm audit clean (LHCI removal is a positive), vanilla JS, least-privilege-ish workflow, no secrets. Lost points: bundler-audit flags addressable / json (build-time); polyfill.io reference; GA loads by default.
Legal and licensing risk	4	5	MIT present; TOC properly attributed (allejo, MIT); self-hosted OFL-class fonts. Minor: placeholder eyvan.gemspec metadata.
Documentation and customization guidance	9	10	Excellent README (install, dev, deploy, baseurl, customization, limitations, attribution); centralized assets/data. Minor: doesn't flag the url change; GA "blank disables" claim is incorrect.
Total	94	120	78%

(Score = points earned out of the category weight; $94 \div 120 \times 100 = 78\%$.)

4. Key Findings by Severity

Critical

None. The site builds and deploys; the license is present and permissive; no broken deployment path or unsafe runtime code was found.

High

- **Accessibility violations ship in the template (the site fails its own axe suite).**
 - *Evidence:* npx playwright test against a fresh build fails all 3 specs; distinct axe rules: landmark-unique (moderate), aria-allowed-role (minor, 13 nodes), region (moderate), heading-order (moderate). Sources confirm the causes:
 - Three `<nav aria-label="Social links">` landmarks in `header.html`, `mobile-menu.html`, and `footer.html` (duplicate landmark names).
 - `post-share.html:88,102` applies `role="listitem"` directly to `<a>` / `<button>` inside a `role="list"` container (role not allowed on those elements).
 - `post-toc-mobile.html:59` places the `<h2>` "On this page" outside a landmark.
 - `post.html` emits `<h1 class="c-post__title">` followed by `<h4 class="c-post-share__title">` (skips h2/h3) — confirmed in built post markup.
 - *Impact:* Moderate barriers for assistive-tech users; undermines the template's accessibility claim, especially because the tooling to catch this is already present.
 - *Recommendation:* Give each social-links `nav` a context-specific `aria-label` ("Footer social links", "Header social links", "Mobile social links"); restructure the share list as `<ul role="list"><li>...</li></ul>` (or drop the explicit roles); wrap or relocate the mobile-TOC header inside its `nav`; demote `c-post-share__title` / `c-post-nav__title` to a visually-hidden h2 or non-heading element so the document outline does not skip levels.

Medium

- **Google Analytics loads by default with an empty measurement ID.**
 - *Evidence:* `google_analytics: ""` in `_config.yml`; `head.html:210` and `google-analytics.html` both guard with `{% if site.google_analytics %}`, but Liquid treats `""` as truthy. Built pages contain `src="https://www.googletagmanager.com/gtag/js?id="` on every page (`_site/index.html`, post pages).
 - *Impact:* Unexpected third-party request to Google on every page even when analytics is "disabled"; privacy/perf concern; directly contradicts the include's documented "Leave the value blank ... where tracking should be disabled."
 - *Recommendation:* Guard on a non-empty value, e.g.
`{% if site.google_analytics != "" and site.google_analytics %}` or

```
{% assign ga = site.google_analytics | strip %}{% if ga != "" %} .
```

- **Shipped url: "http://localhost:4000" is emitted into canonical, og:url, and the sitemap.**
 - *Evidence:* `_config.yml:10` ; built post shows
`<link rel="canonical" href="http://localhost:4000/eyvan/...">` , matching `og:url` , and `_site/sitemap.xml <loc>` entries all use `localhost` .
 - *Impact:* If a user deploys via Actions without editing `url` , search engines and social unfurlers receive `localhost` URLs — broken canonicalization and previews.
 - *Recommendation:* Ship a neutral/placeholder production `url` (or empty) and call out in the README that `url` must be set before first deploy; the real GitHub URL is currently only present as a comment.
- **head.html advertises an RSS feed that is never generated.**
 - *Evidence:* `head.html:96` links `rel="alternate" ... href="/feed.xml"` , but `jeekyll-feed` is not in `Gemfile / _config.yml` plugins (only referenced in `eyvan.gemspec`). `_site/feed.xml` does not exist.
 - *Impact:* Broken RSS discovery link (404) for every reader/aggregator.
 - *Recommendation:* Either add and enable `jeekyll-feed` , or remove the feed `<link>` .
- **polyfill.io is referenced in the math include.**
 - *Evidence:* `math.html:63`
`document.write('<script src="https://polyfill.io/v3/polyfill.min.js?features=es6">...')`
.
 - *Impact:* `polyfill.io` is a known-compromised/abandoned domain (2024 supply-chain incident). Although loaded only on `math: true` pages and only when `!window.Promise` (effectively never on modern browsers), referencing the domain at all is a supply-chain liability.
 - *Recommendation:* Remove the polyfill (MathJax 3 targets modern browsers) or self-host a vetted polyfill.
- **Build-time gem advisories.**
 - *Evidence:* `bundler-audit` reports `addressable 2.8.9` (CVE-2026-35611, **High**, ReDoS, fix $\geq 2.9.0$) and `json 2.19.1` (CVE-2026-33210, format-string injection, fix $\geq 2.19.2$). Both are transitive Jekyll build dependencies, not runtime site code.
 - *Impact:* Affects the local/CI build toolchain, not the deployed static HTML; risk is limited but real for the build environment.
 - *Recommendation:* `bundle update addressable json` to pick up patched versions.
- **Non-site tooling files are published into _site .**
 - *Evidence:* `_site` contains `package.json` , `package-lock.json` , `eyvan.gemspec` , `tests/accessibility.spec.js` , and `test-results/` . The `exclude:` list omits these, and `hide_test_pages.rb` only removes test *pages*, not static files. (Playwright even discovered the leaked spec copies inside built output during this audit.)
 - *Impact:* Tooling/test artifacts get uploaded as part of the Pages artifact and served publicly — clutter and minor information exposure.

- *Recommendation:* Add `package.json` , `package-lock.json` , `eyvan.gemspec` , `tests` , and `test-results` to `_config.yml` `exclude` .

Low

- **Images lack width / height attributes** (`post.html` `cover`, `post-card.html` , `entry-meta.html` `avatar`) — `loading="lazy"` is present, but missing intrinsic dimensions risks cumulative layout shift. *Recommendation:* add width / height (or aspect-ratio CSS) where practical.
- **Enabling orcid or medium social links breaks the build.** `social-links.html:64,67` maps them to `orcid.svg` / `medium.svg` , which do not exist in `_includes/icons/` ; the missing-include would fail the build. Documented in the include's Notes, but still fragile. *Recommendation:* ship the two icons or guard the include.
- **404 page mentions a search that does not exist** ("Maybe try a search ..."); the README explicitly lists search as out of scope. *Recommendation:* reword the 404 copy.
- **eyvan.gemspec has placeholder metadata** (`authors = ["xxx"]` , `email = ["xxx"]` , `version = "0.1.0"` vs `package.json 1.0.0`) and depends on `jeekyll-feed` which isn't wired in. *Recommendation:* fill in or remove the gemspec if gem distribution isn't intended.
- **Default OG-image fallback path is wrong.** `head.html:76` falls back to `/assets/images/hero-placeholder.jpg` , but the asset is `.webp` . Harmless today because `default_og_image` is set, but the fallback is dead. *Recommendation:* fix the extension.

Informational

- `Gemfile.lock` is git-ignored. Conventional for a distributable theme gem, but a site consumed directly benefits from a committed lock for reproducible builds. CI uses `bundler-cache: true` and resolves fine regardless.
- Demo images are heavy (`avatar.webp` / `hero-placeholder.webp` $\approx$ 283 KB each) — fine as replaceable demo content, but worth optimizing before reuse.
- The demo "Front Matter Field Reference" post discloses it was AI-generated — good transparency for example content.

5. Detailed Category Review

5.1 Build and Deployment Reliability

`bundle install` and `bundle exec jeekyll build` succeed with no warnings. Builds at `--baseurl "/eyvan"` and `--baseurl ""` both complete in $\sim$ 0.5 s. A full scan of built HTML and compiled CSS found **no** hardcoded root-relative `href` / `src` / `url()` — every link flows through `relative_url` / `absolute_url` , so both project-page and user/org deployments are correct. The Actions workflow is appropriate and expected (the `jeekyll/tagging` plugin precludes the native builder); it uses

scoped permissions (contents: read , pages: write , id-token: write), concurrency control, and the standard upload-pages-artifact / deploy-pages flow. Points were lost for deploy-as-is correctness, not build mechanics: the shipped url: localhost propagates into canonical/ og:url /sitemap, the advertised /feed.xml 404s, and tooling files leak into the published _site .

5.2 Jekyll Architecture and Content Model

This is the template's strongest area. Layouts (default → homepage / page / post / tag-page) are thin and compose focused includes; every include carries a structured header documenting purpose, structure, accessibility, and data dependencies. The posts-as-projects model is implemented consistently (homepage previews 6 posts, projects.html lists all, tag pages group by tag) and is clearly documented as intentional. The media system (figure.html , video.html , audio.html , table-caption.html , ref.html) shares a figure counter, supports single/multi-image grids, self-hosted and embedded video with accessible <iframe title> /captions, aspect-ratio classes, and a numbered="false" opt-out. The vendored toc.html (allejo/jekyll-toc) is reused for both desktop and mobile TOC. Intended behaviors (global read time, opt-in crossrefs , opt-in math) behave as documented.

5.3 Configuration and Front Matter Design

_config.yml is well-organized and commented, with sensible defaults (layout: default , posts → post + share: true), a readable permalink (/projects/:title/), compressed Sass, and global read-time knobs. Optional front matter degrades gracefully throughout (page.image , subtitle , tags , share , toc are all conditionals). Two design defects hold the score back: the analytics empty-string guard does not actually disable analytics, and the production url default is localhost .

5.4 Liquid Code Quality and Template Structure

Liquid is consistently readable, with parameterized includes (navigation.html , theme-toggle.html , section-heading.html all take modifier / aria_label /level args) and careful missing-field handling (default: filters, entry-meta.html author fallback chain, section-heading.html validates heading_level / modifier). External-link detection and active-state normalization in navigation.html are thoughtful. Deductions: the empty-string truthiness bug in the analytics guard, and role="listitem" placed on interactive elements in post-share.html .

5.5 SCSS Architecture and Maintainability

The _sass tree maps cleanly onto ITCSS 0–7. Responsibilities are correctly separated (settings = tokens, tools = mixins/motion, generic = reset/normalize/fonts, base = element defaults, objects = layout abstractions, components = UI, layouts = page composition, trumps = utilities/a11y/print/motion/states). BEM prefixes (o- , c- , l- , u- , is-) are used consistently. All 46 !important declarations live in the trumps layer (visibility/a11y/states) where overriding intent is appropriate; there are **no ID selectors**. A

multi-theme token system (Persian palette, art/science light/dark) drives the design. This is maintainable and customization-safe.

5.6 Accessibility

Foundations are good: a skip link (`u-skip-link + 7-trumps/_ally.scss`), semantic header / main / footer / nav / article landmarks, `aria-expanded / aria-controls` on the menu and mobile-TOC toggles, `aria-current="page"` in nav, `aria-hidden` on decorative SVGs, visually-hidden labels on icon-only controls, `prefers-reduced-motion` handling, and focus states. However, running the project's **own** Playwright + axe suite against a fresh build fails all three specs with four distinct rules: `landmark-unique` (three identically-labelled "Social links" navs), `aria-allowed-role` (`role="listitem"` on `<a> / <button>`), `region` (mobile-TOC heading outside a landmark), and `heading-order` (`h1 → h4`). These are concrete, source-confirmed defects, which is why this category is the largest single point loss despite strong fundamentals.

5.7 Performance and SEO

Positives: self-hosted variable WOFF2 fonts with `font-display: swap` (no Google Fonts request), compressed CSS (~67 KB for a full multi-theme design system), `loading="lazy"` on images/embeds, deferred small vanilla JS, MathJax loaded only on `math: true` pages, syntax highlighting via Rouge (build-time, theme-aware), and a complete SEO/OG/Twitter/canonical metadata block plus `jeekyll-sitemap`. Negatives: images carry no `width / height` (CLS risk); the GA tag fires on every page with an empty id; `polyfill.io` is referenced; canonical/sitemap URLs are `localhost` as shipped; the RSS link 404s; and demo images are large (~283 KB). Per the audit scope, no Lighthouse/PageSpeed tooling was run or reintroduced.

5.8 Security, Dependencies, and Supply Chain

`npm audit` reports **0 vulnerabilities** in the QA dev tooling (`pa11y-ci`, Playwright, axe), and the deliberate removal of `@lhci/cli` is a positive hygiene signal. Site JS is small, vanilla, and shows no `eval / atob / obfuscation` (the only `document.write` is the polyfill loader in `math.html`). The Actions workflow uses scoped permissions and no unsafe triggers. No secrets were surfaced (gitleaks unavailable; static review found none). Concerns: `bundler-audit` flags addressable (High, ReDoS) and `json` (format-string) as build-time transitive deps; `polyfill.io` is referenced; and GA loads by default. No remote-theme dependency. No Dependabot/Renovate config is present.

5.9 Legal and Licensing

MIT LICENSE is present and permissive for reuse/modification, mirrored by `package.json`. The vendored TOC include retains its upstream allejo/jeekyll-toc MIT attribution in-file. Fonts (Literata, Space Grotesk, JetBrains Mono) are self-hosted WOFF2 subsets of openly-licensed (OFL-class) families — redistributable,

though no explicit font-license note ships in-repo. The README includes an Attribution section instructing downstream users to preserve upstream notices. Example/demo content is template-authored (one post flags AI generation). This is technical/legal-risk screening, not legal advice; the only blemish is the placeholder `eyvan.gemspec` metadata.

5.10 Documentation and Customization Guidance

The README is beginner-appropriate and complete: what Eyvan is and who it's for, requirements, install, local dev, GitHub Pages-via-Actions deployment (with project vs. user/org `baseurl` examples), custom domain note, content/front-matter guidance, a "Reusable Includes" section, a candid "Limitations" section, and an "Attribution" section. Customization flows through obvious files: `_config.yml`, `_data/*.yml` (`author`, `hero`, `navigation`, `social-links`, `share`, `footer`), SCSS tokens in `_settings`, and clearly named `assets/` folders; favicon/logo/OG assets are centralized and referenced via `relative_url`. The in-repo "Front Matter Field Reference" demo post is excellent. Two doc gaps cost a point: the README does not warn that `url` must be changed before deploy, and the analytics "leave blank to disable" claim is inaccurate given the truthiness bug.

6. Commands Run

```
pwd && ls -la && ruby --version; bundle --version; jekyll --version; node --version; npm --v
```

Result: pass — Ruby 4.0.1, Bundler 4.0.8, Jekyll 4.4.1, Node v24.12.0, npm 11.8.0.

```
find . -maxdepth 3 -type f ... | sort
```

Result: pass — repository mapped.

```
bundle install
```

Result: pass — 38 gems installed, no errors.

```
bundle exec jekyll build --baseurl "/eyvan" --destination _site_subpath
bundle exec jekyll build --baseurl "" --destination _site_root
bundle exec jekyll build
```

Result: pass — all clean (~0.5 s each). (Temporary `_site_subpath` / `_site_root` dirs were created for comparison and then removed.)

```
grep -rhoE '(href|src)="/[^"]*"' --include="*.html" _site_subpath | grep -v '/eyvan' # + 1
```

Result: pass — no hardcoded root-relative links found.

```
bundle exec jekyll serve --no-watch --skip-initial-build --detach --port 4000
curl -s -o /dev/null -w "%{http_code}" http://127.0.0.1:4000/eyvan/ # + post URL
```

Result: pass — server returned 200 for home and post (used only to run the a11y suite; later stopped with `pkill`).

```
npx playwright test # Playwright + axe accessibility suite
npx playwright test --reporter=line | grep helpUrl | ... # extract rule ids
```

Result: fail (expected/informative) — violations: `landmark-unique` , `aria-allowed-role` , `region` , `heading-order` .

```
npm audit
```

Result: pass — 0 vulnerabilities.

```
bundle-audit check --update
```

Result: fail (advisories found) — `addressable 2.8.9` (High) and `json 2.19.1` ; both build-time transitive deps.

```
gitleaks detect --source .
```

Result: not run — gitleaks not installed (not installed globally per command-safety rules). Static review surfaced no secrets.

```
bundle outdated
```

Result: not run — superseded by `bundler-audit` , which gave the actionable security signal; avoided to limit network/time.

```
npm run a11y / a11y:sitemap (pa11y-ci)
```

Result: not run — no `.pa11yci` config file ships and the `test:a11y` script is the Playwright suite, which was run directly. `pa11y-ci` would target the same served build; the Playwright/axe results already provide the violation evidence.

```
npx playwright install
```

Result: not run — browsers were already present (the suite executed), so no download was needed.

7. Adoption or Release Recommendation

Adopt with minor improvements. Eyvan is structurally excellent — clean architecture, correct subpath handling, disciplined Sass, good docs, and real QA tooling — and there is **no Critical blocker**: it builds, deploys, is MIT-licensed, and contains no unsafe runtime code. The issues that keep it from "adopt as-is" are a cluster of small, well-localized fixes: the analytics-by-default bug, four accessibility violations its own suite already catches, the `localhost` production `url`, the dangling RSS link, the `polyfill.io` reference, and the leaked tooling files. Each is a few lines. Fixing the High/Medium items (especially the GA guard, the `a11y` set, and `url`) before a public release is strongly advised.

8. Prioritized Remediation Plan

Priority	Recommendation	Severity	Effort	Expected Benefit
1	Fix the analytics guard so a blank <code>google_analytics</code> truly disables the tag (<code>!= ""</code>); stop the empty-id Google request on every page.	Medium	Low	Removes unexpected third-party request; matches documented behavior; privacy/perf.
2	Resolve the four axe violations: unique social-nav labels, restructure share list (<code>/</code> instead of <code>role="listitem"</code> on links), move mobile-TOC heading inside its landmark, and fix the <code>h1→h4</code> heading skip.	High	Medium	Makes the template pass its own <code>a11y</code> suite; real assistive-tech improvement.
3	Ship a placeholder/empty production <code>url</code> and document that it must be set before deploy.	Medium	Low	Correct canonical/OG/sitemap URLs on first deploy; better SEO/social.
4	Either enable <code>jeekyll-feed</code> or remove the <code>/feed.xml</code> <code><link></code> in <code>head.html</code> .	Medium	Low	Eliminates a 404 RSS link / delivers a working feed.

Priority	Recommendation	Severity	Effort	Expected Benefit
5	Remove the <code>polyfill.io</code> dependency from <code>math.html</code> (or self-host).	Medium	Low	Closes a supply-chain exposure.
6	<code>bundle update addressable json</code> ; consider adding Dependabot.	Medium	Low	Patches build-time advisories; ongoing hygiene.
7	Exclude <code>package.json</code> , <code>package-lock.json</code> , <code>eyvan.gemspec</code> , <code>tests</code> , <code>test-results</code> from the build.	Medium	Low	Keeps tooling/test artifacts out of the published site.
8	Add <code>width / height</code> (or <code>aspect-ratio</code>) to <code>cover</code> , <code>card</code> , and <code>avatar</code> images.	Low	Medium	Reduces layout shift (CLS).
9	Ship <code>orcid.svg</code> / <code>medium.svg</code> (or guard the mapping); fix 404 copy; correct OG fallback extension; complete/remove <code>eyvan.gemspec</code> .	Low	Low	Removes build-break footguns and small inconsistencies.

9. Optional Enhancements and Future Development

Not counted against the score; deliberate, documented omissions are listed here, not as findings.

- **Dedicated projects collection** (separate from `_posts`). *Rationale:* lets writing and project entries diverge in fields/URLs if the posts-as-projects model becomes limiting. *Effort:* Medium. *Risk:* adds a second content path to document — keep optional to preserve simplicity.
- **Per-post read-time override** alongside the global setting. *Rationale:* curated estimates for atypical posts (heavy code/math). *Effort:* Low. *Risk:* minimal.
- **Optional client-side search** (e.g. a prebuilt JSON index + tiny vanilla search). *Rationale:* the only notable navigation gap for larger archives. *Effort:* Medium. *Risk:* adds JS/index weight — gate behind a config flag to keep the minimalist default.
- **A working RSS feed** via `jeekyll-feed` (pairs with remediation #4). *Rationale:* the head already advertises one. *Effort:* Low. *Risk:* none.
- **Consent-aware analytics hook** in `google-analytics.html` . *Rationale:* privacy-respecting tracking when enabled. *Effort:* Medium. *Risk:* low if opt-in.

10. Limitations of This Audit

- External/runtime signals were not verified: the live demo site was not fetched, GitHub repository settings and Actions run history are not visible, and adoption/maintainership metrics were not assessed.
- `gitleaks` and `bundle outdated` were not run (`gitleaks` not installed; `bundler-audit` provided the security signal). Secret screening was therefore static only.
- Accessibility was assessed with the project's own Playwright + axe suite plus source review; `pa11y-ci` was not separately run (no shipped `.pa11y-ci`, and it would target the same build). Automated axe checks do not cover all manual a11y criteria (e.g. full keyboard-trap and screen-reader walkthroughs).
- Per scope, no Lighthouse/PageSpeed/WebPageTest tooling was installed or run; performance is assessed statically from build output, so no field/lab scores are reported.
- Color-contrast and visual rendering were not measured pixel-by-pixel; theme/contrast claims rest on token review and axe output, not a manual contrast sweep of every state.
- License compatibility is a technical screen, not legal advice; font-license redistribution terms should be confirmed against each foundry's license before commercial redistribution.

11. Final Notes

Eyvan is structurally sound and genuinely well-engineered: clean ITCSS/BEM Sass, thin layouts over focused and thoroughly-documented includes, correct `baseurl` behavior at both root and subpath, self-hosted assets, opt-in heavy features, and a beginner-friendly README. It is close to ready for public reuse. Before a public release, fix the small but real cluster of defects — chiefly the analytics-loads-by-default bug, the four accessibility violations the project's own tests already flag, and the `localhost` production `url` — and tidy the dangling RSS link, the `polyfill.io` reference, and the leaked tooling files. Everything else (image dimensions/CLS, icon gaps, gemspec metadata, demo-image weight, optional search/feed/collection features) can be improved iteratively without compromising the template's minimalist, content-first intent.